

WYDZIAŁ INFORMATYKI I TELEKOMUNIKACJI
Instytut Informatyki

Praca dyplomowa magisterska

**ANALIZA RUCHU SIECIOWEGO APLIKACJI MOBILNYCH NA
PLATFORMIE ANDROID**

Imię Nazwisko, nr albumu 123456Imię Nazwisko, 123456

Promotor
dr inż. Imię Nazwisko

POZNAŃ 2025

Streszczenie

Przedmiotem pracy jest analiza ruchu sieciowego generowanego przez wybrane aplikacje mobilne systemu Android. Zaimplementowano środowisko przechwytywania (mitmproxy, tcpdump), normalizacji i klasyfikacji z uwzględnieniem protokołów (HTTP/1.1, HTTP/2, QUIC), szyfrowania TLS oraz aspektów prywatności (domeny trackingowe, identyfikatory). Wyniki obejmują statystyki protokołów, charakterystykę ruchu według kategorii aplikacji oraz ocenę ryzyk potencjalnego ujawniania metadanych.

Słowa kluczowe: Android, analiza ruchu, TLS, QUIC, prywatność, mitmproxy.

Abstract

This thesis investigates network traffic generated by selected Android applications. A modular environment for traffic interception (mitmproxy, tcpdump), normalization and classification was implemented, focusing on protocols (HTTP/1.1, HTTP/2, QUIC), TLS encryption and privacy aspects (tracking domains, identifiers). Results include protocol usage statistics, traffic characteristics across app categories, and an assessment of potential metadata exposure risks.

Keywords: Android, network traffic analysis, TLS, QUIC, privacy, mitmproxy.

Spis treści

Spis rysunków	5
Spis tabel	7
Spis listingów	11
Wykaz skrótów	13
1 Wstęp	15
1.1 Motywacja	15
1.2 Cel i zakres pracy	16
1.3 Pytania badawcze i hipotezy	17
1.4 Metody i podejście	17
1.5 Struktura pracy	17
2 Przegląd literatury i technologii	19
2.1 Architektura systemu Android	19
2.2 Model bezpieczeństwa	19
2.3 Protokoły	19
2.4 Techniki analizy ruchu	19
2.5 Prywatność i tracking	19
2.6 Powiązane badania	19
3 Metodyka badawcza	21
3.1 Kryteria doboru aplikacji	21
3.2 Środowisko testowe	21
3.3 Procedura przechwytywania	21
3.4 Automatyzacja interakcji	21
3.5 Model danych i metryki	21
3.6 Anonimizacja i etyka	21
3.7 Walidacja	21
4 Architektura rozwiązania	23
4.1 Przegląd komponentów	23
4.2 Diagram wysokopoziomowy	23
4.3 Przepływ danych (ETL)	23
4.4 Struktura repozytorium	23
4.5 Model normalizacji	23
4.6 Rozszerzalność	23

5	Implementacja	25
5.1	Moduł przechwytywania	25
5.2	Hooki mitmproxy	25
5.3	Parser i normalizacja	25
5.4	Klasyfikacja domen	25
5.5	Agregacje i raporty	25
5.6	Testy	25
6	Eksperymenty i wyniki	27
6.1	Plan eksperymentalny	27
6.2	Charakterystyka próbek	27
6.3	Wykorzystanie protokołów	27
6.4	Analiza domen trackingowych	27
6.5	Czasy odpowiedzi i rozmiary	27
6.6	Ograniczenia	27
7	Aspekty bezpieczeństwa i prywatności	29
7.1	Szyfrowanie i wersje TLS	29
7.2	Certificate pinning	29
7.3	Potencjalne wycieki metadanych	29
7.4	Domeny trackingowe	29
7.5	Implikacje	29
8	Dyskusja	31
8.1	Interpretacja wyników	31
8.2	Porównanie z literaturą	31
8.3	Zagrożenia dla ważności	31
8.4	Perspektywa praktyczna	31
9	Wnioski i dalsze prace	33
9.1	Podsumowanie	33
9.2	Odpowiedzi na pytania badawcze	33
9.3	Możliwe rozszerzenia	33
	Bibliografia	35
	Dodatkowe wykresy	37
	Konfiguracja środowiska	39
	Parametry mitmproxy	39
	Skrypt automatyzacji ADB (fragment)	39
	Struktura katalogów danych	39

Spis rysunków

4.1	Architektura modułowa środowiska analitycznego (schemat).	23
-----	---	----

Spis tabel

Spis algorytmów

Spis listingów

1	Hook mitmproxy zapisujący metadane żądań	25
---	--	----

Wykaz skrótów

API – Application Programming Interface
TLS – Transport Layer Security
HTTP – HyperText Transfer Protocol
QUIC – Quick UDP Internet Connections
CDN – Content Delivery Network
DNS – Domain Name System
ADB – Android Debug Bridge

Rozdział 1

Wstęp

1.1 Motywacja

Rynek aplikacji mobilnych stał się dominującym kanałem konsumpcji treści i usług cyfrowych. Według danych branżowych dotyczących penetracji dostępu mobilnego (71% globalnej populacji z subskrypcją mobilną do 2023 r.) [1] oraz aktualnych statystyk udziału ruchu WWW (ponad 50% globalnych page views pochodzi z urządzeń mobilnych) [2] środowisko mobilne stanowi kluczowy obszar analizy zachowań komunikacyjnych i ryzyk prywatności. W ekosystemie Androida współistnieją tysiące bibliotek firm trzecich (analityka, reklama, personalizacja, antyfraud), które wprowadzają dodatkowe warstwy komunikacji sieciowej – często poza świadomością użytkownika i częściowo także poza kontrolą dewelopera końcowej aplikacji (zależności łańcuchowe). Ta rosnąca heterogeniczność przekłada się na trudności w:

- a) uzyskaniu przejrzystości jakie protokoły i domeny są wykorzystywane,
- b) ocenie ryzyka ekspozycji metadanych (host, czas, wielkości transferów) mimo powszechnego szyfrowania treści,
- c) porównywalności zachowań komunikacyjnych między kategoriami aplikacji (komunikatory, multimedia, finanse, gry),
- d) tworzeniu powtarzalnych narzędzi badawczych radzących sobie z ewolucją protokołów (HTTP/2, HTTP/3/QUIC) i mechanizmami obronnymi (certificate pinning).

Drugi wektor motywacyjny stanowi szybka adopcja nowych protokołów transportowych i warstw aplikacyjnych. QUIC (standaryzowany jako HTTP/3 [3]) przenosi część logiki transportu do przestrzeni użytkownika (UDP + TLS 1.3 [4]), co zmienia charakterystykę obserwowalnych cech przepływów: klasyczne estymatory opóźnień i retransmisji z poziomu TCP stają się mniej bezpośrednie, a analiza pakietów jest utrudniona przez szyfrowanie większej liczby pól. W konsekwencji wcześniejsze proporcje protokołów publikowane w literaturze mogą być nieaktualne dla obecnych wersji popularnych aplikacji.

Kolejnym aspektem jest prywatność i otoczenie regulacyjne. RODO (GDPR), a także DMA-/DSA w UE akcentują minimalizację i przejrzystość przetwarzania. Architektura „multi-endpoint” (API własne + analityka + reklamy + antyfraud + CDN/edge) prowadzi do gęstych, równoległych zestawów połączeń tuż po interakcji użytkownika. Nawet przy pełnym szyfrowaniu treści korelacja metadanych (częstotliwość, rozmiary odpowiedzi, domeny) może ujawniać wzorce użycia funkcji (pattern-of-life). Transparentność takich wzorców jest ograniczona zarówno dla użytkownika, jak i

audytorów; narzędzia systemowe dają uogólniony obraz, a techniki inwazyjne (hooking, dynamic instrumentation) bywają blokowane przez mechanizmy anty-tampering.

Istnieje także motywacja praktyczna stworzenia lekkiego, powtarzalnego środowiska badawczego balansującego między:

- **Zasięgiem obserwacji** (kompletność metadanych HTTP[S]),
- **Inwazyjnością** (brak konieczności rootowania, minimalne modyfikacje),
- **Zgodnością prawną i etyczną** (anonimizacja identyfikatorów, brak utrwalania treści wrażliwych).

Istniejące narzędzia (np. *mitmproxy*) zapewniają bazowy przechwyt, ale wymagają rozszerzeń o: (i) normalizację do spójnego formatu, (ii) klasyfikację domen (funkcjonalna / tracking / infrastrukturalna), (iii) agregację metryk (udział protokołów, rozkłady czasów), (iv) automatyzację interakcji (ADB/UI scripting), (v) politykę anonimizacji.

Z naukowego punktu widzenia identyfikowane luki obejmują:

- L1** Brak bieżących, empirycznych pomiarów dystrybucji HTTP/1.1 vs HTTP/2 vs QUIC w popularnych aplikacjach.
- L2** Ograniczone porównania między kategoriami aplikacji a zachowaniami komunikacyjnymi.
- L3** Niedostatek jawnych metryk ryzyka prywatności bazujących wyłącznie na metadanych.
- L4** Fragmentaryczne dane o wpływie certificate pinning na pokrycie przechwyty.

Interesariusze:

- **Użytkownik** – zyskuje pośrednio poprzez privacy-by-design.
- **Deweloper** – możliwość audytu nadmiarowych zależności.
- **Audytora bezpieczeństwa** – metryki priorytetyzacji ryzyka.
- **Społeczność naukowa** – powtarzalny pipeline do dalszych badań.

Kluczowe osie motywacji:

1. **Ewolucja protokołów i szyfrowania**
2. **Prywatność i regulacje**
3. **Złożoność komponentów trzecich**
4. **Replikowalność i standaryzacja**

1.2 Cel i zakres pracy

Cel: Opracowanie oraz ewaluacja środowiska do systematycznej analizy ruchu sieciowego aplikacji Android i identyfikacji wzorców komunikacyjnych oraz ryzyk prywatności. Zakres obejmuje: (i) środowisko przechwytywania, (ii) normalizację i klasyfikację ruchu, (iii) definicję metryk, (iv) eksperymenty na wybranym zbiorze aplikacji, (v) analizę protokołów i domen trackingowych.

1.3 Pytania badawcze i hipotezy

Pytanie badawcze: Jakie protokoły transportowe dominują w ruchu popularnych aplikacji?

Hipoteza: Ponad 60% żądań wykorzystuje HTTP/2 lub QUIC.

Pytanie badawcze: Czy aplikacje multimedialne kierują większy odsetek ruchu do domen analitycznych niż komunikatory?

Hipoteza: Aplikacje multimedialne mają wyższy udział żądań do domen trackingowych.

1.4 Metody i podejście

Obserwacja black-box: przechwytywanie TLS z własnym CA, heurystyki klasyfikacji domen, agregacja metryk i analiza.

1.5 Struktura pracy

Rozdział 2: literatura i kontekst; 3: metodyka; 4: architektura; 5: implementacja; 6: eksperymenty i wyniki; 7: bezpieczeństwo i prywatność; 8: dyskusja; 9: wnioski; Aneksy.

Rozdział 2

Przegląd literatury i technologii

2.1 Architektura systemu Android

Krótką charakterystyka warstw (kernel, HAL, ART, framework). Odniesienia do dokumentacji.

2.2 Model bezpieczeństwa

Sandbox, uprawnienia, Store review, mechanizmy ograniczające przechwytywanie (certificate pinning).

2.3 Protokoły

HTTP/1.1, HTTP/2 (multiplexing), HTTP/3/QUIC (UDP, 0-RTT), TLS 1.3 skrócenie handshake [3], [4].

2.4 Techniki analizy ruchu

Narzędzia: tcpdump, Wireshark, mitmproxy, Frida (hookowanie), emulator vs urządzenie fizyczne.

2.5 Prywatność i tracking

Mechanizmy identyfikacji użytkownika, rola domen reklamowych, fingerprinting.

2.6 Powiązane badania

Syntetyczne zestawienie publikacji – wykazać luki (np. niedostateczna analiza QUIC w mobilnych aplikacjach konsumenckich).

Rozdział 3

Metodyka badawcza

3.1 Kryteria doboru aplikacji

Popularność (rankingi store), kategorie (komunikacja, multimedia, finanse), aktualność wersji.

3.2 Środowisko testowe

Sprzęt (model urządzenia), wersja Android, konfiguracja sieci (oddzielony SSID), kontrola tła (tryb samolotowy przed startem sesji).

3.3 Procedura przechwytywania

Instalacja certyfikatu CA dla mitmproxy, konfiguracja proxy systemowego, ograniczenia w wypadku pinningu.

3.4 Automatyzacja interakcji

Skrypty ADB / uiautomator generujące sekwencje działań, logowanie timestampów.

3.5 Model danych i metryki

Pola: timestamp, host, ścieżka, metoda, kod statusu, rozmiary (request/response), protokół (HTTP/2 / QUIC), kategoria domeny, czas odpowiedzi.

3.6 Anonimizacja i etyka

Hashowanie identyfikatorów, odrzucanie payloadów binarnych zawierających potencjalne dane osobowe, brak logowania treści formularzy.

3.7 Walidacja

Losowa weryfikacja spójności liczby pakietów vs liczby zarejestrowanych żądań; test powtarzalności (2 przebiegi).

Rozdział 4

Architektura rozwiązania

4.1 Przegląd komponentów

Opis modułów: przechwytywanie, ekstrakcja, normalizacja, klasyfikacja, agregacja, wizualizacja.

4.2 Diagram wysokopoziomowy

RYSUNEK 4.1: Architektura modułowa środowiska analitycznego (schemat).

4.3 Przepływ danych (ETL)

Kolejne etapy: capture -> parse -> enrich -> store -> stats.

4.4 Struktura repozytorium

Opis katalogów (np. scripts/, data/, analysis/).

4.5 Model normalizacji

Mapowanie surowych atrybutów mitmproxy na ujednolicony rekord JSON/CSV.

4.6 Rozszerzalność

Dodanie nowego klasyfikatora domen lub obsługa innego proxy.

Rozdział 5

Implementacja

5.1 Moduł przechwytywania

Konfiguracja mitmproxy, parametry uruchomienia.

5.2 Hooki mitmproxy

```
1 def response(flow):
2     rec = {
3         "proto": flow.request.scheme,
4         "host": flow.request.host,
5         "path": flow.request.path,
6         "method": flow.request.method,
7         "status": flow.response.status_code,
8         "t_start": flow.request.timestamp_start,
9         "t_end": flow.request.timestamp_end,
10        "length": len(flow.response.raw_content or b"")
11    }
12    save_record(rec)
```

LISTING 1: Hook mitmproxy zapisujący metadane żądań

5.3 Parser i normalizacja

Krok po kroku: walidacja, cast typów, uzupełnianie braków.

5.4 Klasyfikacja domen

Listy znanych trackerów, heurystyki (substring, kategorie TLD, reverse DNS).

5.5 Agregacje i raporty

Obliczanie histogramów, percentyle czasów odpowiedzi.

5.6 Testy

Testy jednostkowe (poprawność mapowania), testy integracyjne (ciąg ETL).

Rozdział 6

Eksperymenty i wyniki

6.1 Plan eksperymentalny

Opis serii sesji, długość, liczba powtórzeń.

6.2 Charakterystyka próbek

Liczba aplikacji, łączna liczba żądań, udział kategorii.

6.3 Wykorzystanie protokołów

Tabela i wykres udziału HTTP/1.1 vs HTTP/2 vs QUIC.

6.4 Analiza domen trackingowych

Odsetek żądań do trackerów per kategoria.

6.5 Czasy odpowiedzi i rozmiary

Rozkłady, mediany, percentyle.

6.6 Ograniczenia

Próbkowanie krótkich okien użycia, brak tła push/pull w długim horyzoncie.

Rozdział 7

Aspekty bezpieczeństwa i prywatności

7.1 Szyfrowanie i wersje TLS

Wykryte wersje, renegotjacje (jeśli obserwowane).

7.2 Certificate pinning

Przypadki utraty widoczności ruchu (fail-open / fail-closed), wpływ na wyniki.

7.3 Potencjalne wycieki metadanych

Parametry w URL, identyfikatory urządzeń, tokeny.

7.4 Domeny trackingowe

Porównanie intensywności ruchu do domen analitycznych.

7.5 Implikacje

Ryzyka dla prywatności użytkownika i rekomendacje (np. ograniczanie uprawnień sieciowych, firewall lokalny).

Rozdział 8

Dyskusja

8.1 Interpretacja wyników

W jakim stopniu dane potwierdzają/obalają hipotezy.

8.2 Porównanie z literaturą

Zestawienie różnic (np. wzrost QUIC vs wcześniejsze badania).

8.3 Zagrożenia dla ważności

Internal: artefakty środowiska testowego; external: różnice regionów geograficznych; konstrukcja: wybór kategorii.

8.4 Perspektywa praktyczna

Wartość dla użytkowników, deweloperów, regulatorów.

Rozdział 9

Wnioski i dalsze prace

9.1 Podsumowanie

Najważniejsze osiągnięcia i wkład.

9.2 Odpowiedzi na pytania badawcze

Zwięzłe odpowiedzi w punktach.

9.3 Możliwe rozszerzenia

Automatyczna detekcja anomalii, uczenie maszynowe do klasyfikacji domen, analiza korelacji z zużyciem energii.

Bibliografia

- [1] „Cisco Annual Internet Report (2018–2023) White Paper,” Cisco, 2020, Prognozy do 2023 r.; m.in. penetracja subskrypcji mobilnych (71% global population with mobile subscription by 2023). adr.: <https://www.cisco.com/c/en/us/solutions/collateral/executive-perspectives/annual-internet-report/white-paper-c11-741490.html> (term. wiz. 17.08.2025).
- [2] StatCounter, *Global Platform Market Share: Desktop vs Mobile vs Tablet*, Udział globalnych page views według platformy; potwierdza >50% dla urządzeń mobilnych (sprawdź dokładny zakres dat), 2025. adr.: <https://gs.statcounter.com/platform-market-share/desktop-mobile-tablet> (term. wiz. 17.08.2025).
- [3] M. Bishop, *HTTP/3*, RFC 9114, 2022. adr.: <https://www.rfc-editor.org/rfc/rfc9114>.
- [4] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018. adr.: <https://www.rfc-editor.org/rfc/rfc8446>.

Dodatkowe wykresy

Dodatkowe wizualizacje (np. szczegółowe histogramy czasów odpowiedzi, rozkłady rozmiarów payloadów).

Konfiguracja środowiska

Parametry mitmproxy

```
mitmproxy --mode regular --set connection_strategy=lazy
```

Skrypt automatyzacji ADB (fragment)

Przykład sekwencji wejść użytkownika generowanych sztucznie.

Struktura katalogów danych

Opis: raw/ processed/ reports/.

Imię Nazwisko (2025)

Instytut Informatyki, Wydział Informatyki i Telekomunikacji
Politechnika Poznańska

Skład przy użyciu systemu L^AT_EX (Overleaf).